ITA1404

Total points 50/50

NAME

B.Vani

REG NO

192472348

✓ **1.** A company authorizes a security professional to test only its web server. During testing, the professional notices another vulnerable database server. What should the ethical hacker apply in this situation? 1/1

- A) Test the database immediately
- B) Remain within the authorized scope and report the observation ✓
- C) Exploit the database to verify the weakness
- D) Download the database for analysis

✓ 2. A security tester receives written permission to assess a company network. Which action should the tester perform first to apply ethical hacking principles? 1/1

- ○ A) Launch vulnerability exploits
- ◉ B) Review the authorized scope and rules of engagement ✓
- ○ C) Disable the firewall
- ○ D) Collect employee passwords

✓ 3. An ethical hacker discovers confidential customer information during an authorized penetration test. How should the hacker apply confidentiality principles? 1/1

- ○ A) Copy the information to a personal device
- ○ B) Share it with other testers outside the project
- ◉ C) Protect the information and follow the agreed reporting procedure ✓
- ○ D) Publish the information as evidence

✓ 4. A student wants to practice vulnerability scanning on the college network. How should ethical hacking principles be applied? 1/1

- ○ A) Scan the network without informing anyone
- ◉ B) Obtain authorization before performing the scan ✓
- ○ C) Scan only during the night
- ○ D) Hide the source IP address

✓ 5. During an authorized assessment, a tester identifies a critical vulnerability. Which action applies responsible disclosure correctly? 1/1

- ○ A) Post the vulnerability publicly immediately
- ◉ B) Report it securely to the authorized organization ✓
- ○ C) Sell the information
- ○ D) Ignore the vulnerability

✓ 6. A penetration tester is authorized to test IP addresses 192.168.1.10–192.168.1.20. Which target can the tester ethically assess? 1/1

- ○ A) 192.168.1.5
- ○ B) 192.168.1.25
- ◉ C) 192.168.1.15 ✓
- ○ D) 192.168.2.10

✓ 7. A tester accidentally gains access to sensitive payroll records during an assessment. What should the tester do? 1/1

- ○ A) Modify the records to demonstrate access
- ○ B) Download all records
- ◉ C) Minimize further access and report the finding ✓
- ○ D) Share screenshots publicly

✓ 8. A company asks an ethical hacker to assess its website without affecting normal users. Which approach should the hacker apply? 1/1

- ◉ A) Perform only approved, controlled, non-destructive testing ✓
- ○ B) Shut down the website
- ○ C) Delete vulnerable files
- ○ D) Modify customer accounts

✓ 9. An employee discovers a security flaw in the organization's internal application. How should proper disclosure be applied? 1/1

- ○ A) Publish the flaw online
- ◉ B) Report it through the organization's approved security channel ✓
- ○ C) Exploit the flaw repeatedly
- ○ D) Inform unrelated organizations

✓ 10. A tester is given authorization that expires at 6:00 PM. At 6:15 PM, testing is incomplete. What should the tester do? 1/1

- ○ A) Continue until testing is finished
- ◉ B) Stop testing and obtain renewed authorization before continuing ✓
- ○ C) Continue without recording the activity
- ○ D) Change the system time

✓ 11. A security professional wants to demonstrate the impact of a vulnerability. Which action best applies ethical hacking practice? 1/1

- ○ A) Cause maximum possible damage
- ◉ B) Use the least harmful approved method to demonstrate the risk ✓
- ○ C) Delete system files
- ○ D) Publish confidential data

✓ 12. A penetration tester discovers login credentials while performing an authorized assessment. How should the credentials be handled? 1/1

- ○ A) Store them publicly
- ○ B) Use them on unrelated systems
- ◉ C) Protect them and use them only as permitted by the assessment scope ✓
- ○ D) Share them with friends

✓ 13. A company permits testing of its web application but specifically prohibits denial-of-service testing. Which action should the tester take? 1/1

- ○ A) Perform denial-of-service testing anyway
- ◉ B) Follow the restriction and avoid denial-of-service testing ✓
- ○ C) Perform it outside office hours
- ○ D) Ask another person to perform it

✓ 14. An ethical hacker finds a vulnerability that could expose thousands of customer records. Which response correctly applies professional ethics? 1/1

- ○ A) Download all customer records
- ◉ B) Document the vulnerability while minimizing exposure of customer data ✓
- ○ C) Publish sample customer records
- ○ D) Use the data for another project

✓ 15. A tester realizes that a scanning tool is sending requests to systems outside the approved IP range. What should the tester do? 1/1

- ○ A) Allow the scan to continue
- ◉ B) Stop or reconfigure the scan to remain within scope ✓
- ○ C) Increase the scanning speed
- ○ D) Ignore the issue

✓ 16. An organization hires a penetration tester to evaluate its network. Which document should be applied to determine permitted and prohibited activities? 1/1

- ◉ A) Rules of engagement ✓
- ○ B) Employee attendance record
- ○ C) Software installation guide
- ○ D) Marketing report

✓ 17. A researcher discovers a vulnerability in a public website without prior authorization. What is the most appropriate ethical action? 1/1

- ○ A) Exploit it to determine its full impact
- ◉ B) Avoid unauthorized exploitation and use the site's approved vulnerability-reporting process if available ✓
- ○ C) Download user information
- ○ D) Change the vulnerable code

✓ 18. During testing, an ethical hacker finds evidence of an unexpected serious security issue. What should the hacker do? 1/1

- ○ A) Ignore it because it was unexpected
- ◉ B) Follow the agreed escalation and reporting procedure ✓
- ○ C) Delete the evidence
- ○ D) Publish the evidence immediately

✓ 19. A penetration tester completes an assessment and has temporary copies of sensitive data collected under authorization. What should be done according to the agreed data-handling policy? 1/1

- ○ A) Keep the data permanently
- ○ B) Transfer it to a personal computer
- ◉ C) Securely retain or dispose of it according to the agreement ✓
- ○ D) Share it with students

✓ 20. A tester needs to verify a vulnerability that could potentially crash a production server. Which action best applies ethical principles? 1/1

- ○ A) Test it immediately on the production server
- ◉ B) Follow the approved testing procedure and use a safe environment where possible ✓
- ○ C) Crash the server intentionally
- ○ D) Ignore all organizational restrictions

✓ 21. An ethical hacker is asked to test employee awareness using simulated phishing. What should be established before conducting the exercise? 1/1

- (●) A) Authorization, scope, and approved procedures ✓
- ( ) B) Employees' personal passwords
- ( ) C) Access to personal email accounts
- ( ) D) Permission from unrelated companies

✓ 22. A security tester discovers that the approved scope document contains unclear instructions about testing a particular server. What should the tester do? 1/1

- ( ) A) Assume permission is granted
- (●) B) Obtain clarification before testing that server ✓
- ( ) C) Attack the server anonymously
- ( ) D) Test first and ask later

✓ 23. During an authorized assessment, a tester identifies a weak password on an account. Which action appropriately applies ethical hacking principles? 1/1

- A) Post the password online
- B) Use it only as authorized and document the weakness ✓
- C) Use it to access unrelated accounts
- D) Give it to other employees

✓ 24. A company asks a security professional to prepare a report after testing. Which information should be included to support ethical disclosure? 1/1

- A) Vulnerabilities, evidence, risk, and recommended remediation ✓
- B) Personal opinions about employees
- C) Unrelated customer information
- D) Passwords for public distribution

✓ 25. A security team plans an ethical hacking assessment. Which sequence best applies ethical hacking principles? 1/1

- ○ A) Exploit → Obtain permission → Report → Define scope
- ◉ B) Obtain authorization → Define scope → Test → Document → Report ✓
- ○ C) Scan → Publish → Obtain permission → Exploit
- ○ D) Attack → Collect data → Share → Delete evidence

✓ **26.** While officially authorized to test a decentralized cryptocurrency exchange, An internal compliance auditor assumes the contract implicitly includes the building's physical security camera system and proceeds to attack it. Judge the legal validity of this assumption. 1/1

- ◉ A. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- ○ B. It is legally permissible as long as the actor is a certified and licensed professional.
- ○ C. It is standard practice to ensure no blind spots remain in the client's overall audit.
- ○ D. It is a valid assumption if both systems share the same internal IP subnet

✓ 27.An independent ethical hacker is offered a contract to audit a federal tax web portal, but they recently was rejected for a full-time role there last week. Judge the decision to accept this auditing contract 1/1

- (●) A. Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
- ( ) B. Legal and ethical, provided they sign a supplementary non-disclosure agreement
- ( ) C. Acceptable, as long as they only utilize automated scanning tools to remove bias.
- ( ) D. Ethical, as their insider knowledge will result in a more thorough security test.

✓ **28.** Following an engagement against a multi-national bank's mobile app, management strictly asks A corporate security consultant to delete any mention of the CEO's compromised email account in the final official report. Recommend the most ethical response. 1/1

- ( ) A. Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- (●) B. Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
- ( ) C. Agree to the modification, but charge a premium fee for altering official compliance documents.
- ( ) D. Comply with the request, as the client owns the report and retains final editorial rights

✓ **29.** Months after successfully finishing a penetration test on a decentralized cryptocurrency exchange, An internal compliance auditor decides to retain the database of unencrypted credit card transactions on a local home server 'just in case'. Critique this post-engagement practice. 1/1

- (●) A. It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✓
- ( ) B. It is ethically acceptable as long as the home server is disconnected from the public internet.
- ( ) C. It is a standard industry practice to retain client data for long-term historical benchmarking.
- ( ) D. It is legally required to prove the vulnerabilities existed in case of a future audit dispute.

✓ **30.** A network security auditor is offered a contract to audit a logistics and shipping API, but they recently is secretly building a competing software product. Judge the decision to accept this auditing contract. 1/1

- (●) A. Unethical due to a severe conflict of interest that compromises the auditor's objectivity ✓
- ( ) B. Ethical, as their insider knowledge will result in a more thorough security test.
- ( ) C. Legal and ethical, provided they sign a supplementary non-disclosure agreement.
- ( ) D. Acceptable, as long as they only utilize automated scanning tools to remove bias.

✓ **31.** During a monitoring phase, A corporate security consultant detects an active, malicious attack originating against an online retail platform. They immediately respond by deploying a reverse-shell to delete the attacker's tools. Judge this defensive response. 1/1

- A. It is legally protected under international self-defense doctrines for digital property.
- B. It is ethically mandated to prevent further harm to the client's network infrastructure.
- C. It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- D. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓

✓ **32.** Months after successfully finishing a penetration test on a university's research database, A bug bounty participant decides to retain the medical records accessed during the test on alocal home server 'just in case'. Critique this post-engagement practice. 1/1

- A. It is legally required to prove the vulnerabilities existed in case of a future audit dispute.
- B. It is ethically acceptable as long as the home server is disconnected from the public internet.
- C. It is a standard industry practice to retain client data for long-term historical benchmarking
- D. It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✓

✓ **33.** While officially authorized to test a public transportation control system, A junior penetration tester assumes the contract implicitly includes a staging server that closely mirrors production and proceeds to attack it. Judge the legal validity of this assumption. 1/1

- A. It is legally permissible as long as the actor is a certified and licensed professional.
- B. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- C. It is standard practice to ensure no blind spots remain in the client's overall audit.
- D. It is a valid assumption if both systems share the same internal IP subnet

✓ **34.** An internal compliance auditor is offered a contract to audit a regional hospital's network, but they recently has a lucrative side-deal with their top competitor to leak data. Judge the decision to accept this auditing contract. 1/1

- A. Ethical, as their insider knowledge will result in a more thorough security test.
- B. Legal and ethical, provided they sign a supplementary non-disclosure agreement.
- C. Acceptable, as long as they only utilize automated scanning tools to remove bias.
- D. Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓

✓ **35.** A corporate security consultant identifies a vulnerability in an online retail platform without any prior permission and creates a video showing the hack but hides the company name. Classify the hacker profile and evaluate the action. 1/1

- A. Hacktivism; aimed at political reform by exposing the company's weak security posture.
- B. Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
- C. Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓
- D. White hat behavior; entirely ethical and legal since the ultimate goal was system defense.

✓ **36.** An internal compliance auditor identifies a vulnerability in a regional hospital's network without any prior permission and fixes the flaw but leaves a harmless backdoor for themselves. Classify the hacker profile and evaluate the action. 1/1

- A. White hat behavior; entirely ethical and legal since the ultimate goal was system defense.
- B. Hacktivism; aimed at political reform by exposing the company's weak security posture
- C. Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization ✓
- D. Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.

✓ **37.** During a monitoring phase, An independent ethical hacker detects an active, malicious attack originating against a federal tax web portal. They immediately respond by wiping the attacker's database of stolen credentials. Judge this defensive response. 1/1

- (●) A. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓
- ( ) B. It is legally protected under international self-defense doctrines for digital property.
- ( ) C. It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- ( ) D. It is ethically mandated to prevent further harm to the client's network infrastructure

✓ **38.** While assessing a logistics and shipping API, A network security auditor runs a customized payload generator without verifying its impact, which inadvertently locks out all legitimate administrative users. Assess the primary ethical failure in this scenario. 1/1

- ( ) A. A breach of Non-repudiation, as the tool's execution logs were not preserved.
- (●) B. Failure to assess operational risk, directly violating the principle of Availability. ✓
- ( ) C. A violation of Confidentiality, as the system outage likely exposed unencrypted data.
- ( ) D. There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime.

✓ **39.** Upon discovering a severe flaw in a cloud storage provider, A network security auditor contacts the organization and demands $50,000 in Ethereum before providing the vulnerability report. Evaluate this action under ethical hacking laws. 1/1

- A. It is ethically justified if the organization can easily afford the requested compensation.
- B. This is an aggressive but legally recognized negotiation tactic within modern bug bounties.
- C. This constitutes illegal extortion and is classified as malicious black-hat behavior. ✓
- D. It is valid under full disclosure guidelines as compensation for the researcher's time.

✓ **40.** While assessing an online retail platform, A corporate security consultant runs a mass exploitation script without verifying its impact, which inadvertently crashes the primary production database. Assess the primary ethical failure in this scenario. 1/1

- A. There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime
- B. A violation of Confidentiality, as the system outage likely exposed unencrypted data.
- C. Failure to assess operational risk, directly violating the principle of Availability. ✓
- D. A breach of Non-repudiation, as the tool's execution logs were not preserved

✓ **41.** Following an engagement against a federal tax web portal, management strictly asks A freelance vulnerability assessor to falsify the date of the test to meet a regulatory deadline in the final official report. Recommend the most ethical response. 1/1

- A. Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- B. Comply with the request, as the client owns the report and retains final editorial rights.
- C. Agree to the modification, but charge a premium fee for altering official compliance documents.
- D. Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓

✓ **42.** A bug bounty participant is offered a contract to audit a social media startup, but they recently is currently suing the company for wrongful termination. Judge the decision to accept this auditing contract. 1/1

- A. Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
- B. Acceptable, as long as they only utilize automated scanning tools to remove bias.
- C. Ethical, as their insider knowledge will result in a more thorough security test.
- D. Legal and ethical, provided they sign a supplementary non-disclosure agreement.

✓ **43.** While officially authorized to test a logistics and shipping API, A senior security researcher assumes the contract implicitly includes a third-party managed database physically located in the office and proceeds to attack it. Judge the legal validity of this assumption. 1/1

- A. It is a valid assumption if both systems share the same internal IP subnet.
- B. Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- C. It is standard practice to ensure no blind spots remain in the client's overall audit.
- D. It is legally permissible as long as the actor is a certified and licensed professional.

✓ 44.A certified red teamer is hired to test a university's research database. During the engagement, they notice a physically separate HR network is highly vulnerable. The tester decides to deploy a ransomware simulator on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint 1/1

- A. It is legally protected as long as the tester does not monetize or leak the findings.
- B. It is ethically sound because it improves the client's overall security posture.
- C. It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
- D. It violates explicit authorization, risking severe legal liability and breaching ethical boundaries ✓

✓ **45.** During a monitoring phase, A freelance vulnerability assessor detects an active, malicious attack originating against a university's research database. They immediately respond by launching a DDoS attack against the attacker's IP. Judge this defensive response. 1/1

- A. It is legally protected under international self-defense doctrines for digital property.
- B. It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- C. It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓
- D. It is ethically mandated to prevent further harm to the client's network infrastructure.

✓ **46.** Following an engagement against a cloud storage provider, management strictly asks A network security auditor to change the root cause from 'negligence' to 'advanced threat' in the final official report. Recommend the most ethical response. 1/1

- A. Agree to the modification, but charge a premium fee for altering official compliance documents.
- B. Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- C. Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
- D. Comply with the request, as the client owns the report and retains final editorial rights.

✓ **47.** After discovering a critical flaw in a biometric authentication API, A freelance vulnerability assessor reports it privately. The vendor ignores the report for 9 months. Frustrated, the researcher decides to upload an automated exploitation script to GitHub. Critique this disclosure strategy. 1/1

- A. It is ethical as part of the Coordinated Disclosure framework since the grace period expired.
- B. It is unethical as it maximizes risk to the public without providing a viable mitigation path. ✓
- C. It is legally acceptable because the vendor's silence automatically waives their copyright protections.
- D. It is completely justified under the Full Disclosure model to force the vendor into action.

✓ **48.** A network security auditor is hired to test a social media startup. During the engagement, they notice a deactivated test environment is highly vulnerable. The tester decides to create a new administrative account on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint. 1/1

- A. It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
- B. It violates explicit authorization, risking severe legal liability and breaching ethical boundaries. ✓
- C. It is ethically sound because it improves the client's overall security posture.
- D. It is legally protected as long as the tester does not monetize or leak the findings

✓ **49.** Months after successfully finishing a penetration test on a regional hospital's network, An independent ethical hacker decides to retain a complete dump of the customer database on a local home server 'just in case'. Critique this post-engagement practice. 1/1

- A. It is legally required to prove the vulnerabilities existed in case of a future audit dispute.
- B. It is ethically acceptable as long as the home server is disconnected from the public internet.
- C. It is a standard industry practice to retain client data for long-term historical benchmarking.
- D. It blatantly violates the ethical mandate for secure data destruction and strict confidentiality ✓

✓ **50.** A senior security researcher identifies a vulnerability in a public transportation control system without any prior permission and anonymously submits the finding to a public bug tracker. Classify the hacker profile and evaluate the action. 1/1

- A. White hat behavior; entirely ethical and legal since the ultimate goal was system defense.
- B. Hacktivism; aimed at political reform by exposing the company's weak security posture.
- C. Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
- D. Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓

This form was created inside of Saveetha Institute of Medical and Technical Sciences. - Contact form owner

Does this form look suspicious? Report

Google Forms